AZIMI INNOVATION LAB

Agentic AI Masterclass | Session 01

The Boundary Between Proposal, Approval, and Execution

First educational draft | English | Synthetic examples | Owner review required

01 Learning contract

Session 01 explains the security boundary between proposing a change, authorizing a specific proposal, and executing it. By the end, learners should identify who may approve, what an approval binds to, and why a policy ALLOW decision alone must never mutate state.

02 The three-stage mental model

PROPOSE: create an immutable description of a requested change. APPROVE: a trusted human or authorized policy binds consent to the exact proposal. EXECUTE: a separate service verifies every precondition and commits the change atomically. These stages are separate trust boundaries.

03 Worked example: retry_limit

A synthetic agent suggests changing retry_limit from 3 to 5 for a named tenant. The agent is allowed to propose; it is not allowed to grant itself approval. The executor must verify the current value is still 3, that the approval matches the requested change, and that policy permits execution.

04 Proposal data contract

A proposal needs a unique proposal ID, tenant ID, operation, target, expected old value, proposed new value, author, revision, creation time, and canonical digest. Reject missing or malformed fields. Do not accept caller-provided tenant identity without authenticated server-side validation.

05 Canonical digest

Canonicalize the approved proposal fields before hashing. Equivalent content must produce the same bytes and digest; different material content must change the digest. Define field order, encodings, number representation, and version explicitly. A digest proves content identity, not approval authority.

06 Validation and policy

Validate types, allowed operations, numeric bounds, tenant scope, resource scope, actor permissions, and proposal expiry. A policy ALLOW result authorizes progression only; it is not evidence that a transaction executed. Record denials and reasons without leaking secrets.

07 Approval binding

An approval must be issued by a trusted authority and bound to the tenant, proposal digest, revision, operation, target, approver identity, and expiry. Enforce one-time use where required. Approval cannot be silently transferred to a modified proposal.

08 Stale revision and TOCTOU

Time-of-check/time-of-use risks arise when state changes after approval. The executor must compare the expected revision and old value inside the same transaction that writes the new value. A mismatch is a safe rejection, not permission to retry with broader scope.

09 Atomic execution

Within one durable database transaction: verify approval and current state, apply the constrained update, mark the approval consumed, and append an audit event. Roll back all operations on failure. A partial update or double consumption is a security defect.

10 Three outcome families

Distinguish REJECTED before execution, AUTHORIZED but not executed, and COMMITTED successfully. A timeout or unknown result requires reconciliation against durable evidence; it must not be presented as a successful change without confirmation.

11 Replay resistance

Repeated execution requests with the same approval must not apply the change twice. Enforce a unique execution or idempotency key and consumed-approval state in the durable store. Test concurrent requests as well as sequential replays.

12 Tenant isolation

Never trust tenant identifiers supplied only by an agent message. Derive identity from authenticated context and check it at every boundary, including database queries, approvals, logs, and audit retrieval. A valid approval for tenant A must not authorize a change for tenant B.

13 Threat model

Consider forged approvals, cross-tenant access, stale revisions, digest mismatch, replay, race conditions, missing audit entries, excessive agent privileges, and operator error. For each threat, name the preventive control, detective control, and residual limitation.

14 Practical exercise A

Given a proposal to change retry_limit from 3 to 5, classify each event: proposal drafted; approver signs the matching digest; policy returns ALLOW; transaction commits; audit entry is persisted. Identify precisely when state is allowed to change.

15 Practical exercise B

Now change the proposal target after approval. Explain why the original approval is invalid. Repeat with an expired approval, an already-consumed approval, and a changed tenant. For each case, state the expected safe outcome and the evidence required.

16 Evidence and verification

Evidence should include input contract, policy decision, authorization reference, transaction outcome, resulting state, and audit record. Separate observed test results from assertions or illustrative examples. Never claim production-grade security from a synthetic classroom example alone.

17 Session summary

Agents propose. Trusted authorization approves a precise immutable proposal. Deterministic execution verifies identity, scope, revision, replay protection, and transactional integrity before any write. Durable evidence is required to claim completion.

18 Next session bridge

The next lesson can deepen contracts, typed validation, negative testing, and secure orchestration. Learners should retain the distinction between intent, authorization, and verified execution.